Setnayan — Privacy Compliance Dossier

For submission to the National Privacy Commission (NPC), Republic of the Philippines

> **Status: DPO-prepared submission draft — pending final external legal review before filing.** This dossier is prepared by the Data Protection Officer to support NPC registration and to serve as Setnayan's Records of Processing Activities (ROPA) and Privacy Impact Assessment (PIA). It is reasoned from RA 10173 (Data Privacy Act of 2012), its IRR, and NPC issuances. It is **not legal advice**; the Personal Information Controller should have it reviewed by external counsel before submission.

> **Prepared:** 2026-07-12. **Version:** 2.0 (last updated **2026-07-13**). **Governing law:** RA 10173 + IRR + NPC Circulars.

> **Revised 2026-10-22.** This dossier is a 2026-07 snapshot and its body is kept for lineage. Its sub-processor table (§ "Subprocessors") and analytics row were corrected today; **for every other fact, the current statement is the revised pack** — Privacy Manual v1.1, ROPA DPS-01 → DPS-28, NPCRS v1.1 and `NPC_Compliance/00_WHAT_CHANGED_2026-10-22.md` — which supersede this text where they differ (notably: vendor government ID / liveness / AMLC retired 2026-07-03; PostHog removed 2026-10-22; account deletion is request → 24-hour review → anonymise-and-retain; the compressed gallery is kept for life; face selfies erased 12 hours after the event). DPO contact: dpo@setnayan.com.

> **(!) DO NOT LODGE — three defects open (2026-07-20). A compliance pass this session found three statements in this draft that do not match the shipped system, all verified against `origin/main` @ `5b72d625d`. Corrections, drafted replacement text, and the resolutions the owner/DPO must pick are in `Papic_Compliance_Delta_2026-07-20.md`. In summary: (1) §8a `:170` tells the NPC full-res is kept 6 months while the shipped constant is 90 days, and calls the compressed copy retention *"indefinitely"* against the 5-year media period in the filed Data Retention Schedule (Delta §1 — this also blocks all retention marketing copy); (2) the ROPA has no row for Papic-captured photographs and clips — media collected on real events today (drafted row 21 at Delta §2.2, `[PENDING DPO]`); (3) §11 item 7 + ROPA row 20 tell the regulator the Papic Lite pool *"is built but flag-OFF"* — it does not exist (zero code matches) and the product was cancelled 2026-07-20 (Delta §3). None of these establishes unlawful processing; all three are accuracy defects in an unlodged draft, and all three are document edits. A fourth item — whether the RSVP consent copy actually names guest-phone capture and face-sorted delivery — is recorded for DPO ruling at Delta §4.**

> **What changed in v2.0 (2026-07-13):** the ROPA (§3) and the sensitive-personal-information declaration (§5) were expanded from a customer-centric, biometric-only scope to cover **every category the platform actually processes** — self-profile religion / civil status / gender, the dependents & godparents family graph (minors' data), event honoree / specialty data (incl. christening child data and gender-reveal due-date), e-gift receiving handles, and the vendor-verification identity surface. The subprocessor list (§7) was completed (Persona, TikTok, Suno added). Retention (§3, §8a) was aligned to the **Data Retention Schedule (2026-07-11)** with its statutory floors. Driven by the reconciliation in `Privacy_Reconciliation_Home_and_Data_Flows_2026-07-13.md`. Items still requiring owner/counsel action are consolidated in §11.

1. Personal Information Controller (PIC) and Data Protection Officer (DPO)

Field	Detail
Registered business name	SETNAYAN SOFTWARE DEVELOPMENT SERVICE
Legal form	Sole proprietorship (DTI-registered 2026-06-25, national scope)
PIC under RA 10173	The proprietor. A sole proprietorship has no legal personality separate from its proprietor, so the proprietor is the Personal Information Controller.
Data Protection Officer	The proprietor (Indalecio S. Casasola II), serving the DPO function directly
DPO contact	dpo@setnayan.com *(owner-locked 2026-07-24 as the single published DPO contact — this is the address on the live `/privacy` page and the one registered with the NPC DPO system on 2026-07-07. The earlier `dpo@setnayan.com` variant is retired; all documents align to `dpo@setnayan.com`.)*
Data subject response SLA	15 business days *(the period published in the live privacy notice. The older binding Privacy & Security Policy §9 states 7 business days and is to be reconciled up to 15 — see §11.)*
BIR registration	Under the proprietor's existing TIN
NPC registration	To be filed under the registered business name
Public privacy notice	Published at `setnayan.com/privacy` (effective 2026-05-13; **last updated 2026-07-13** via app PR #3215, adding the faith / family / honoree / e-gift disclosures + Anthropic/Suno subprocessors). The opt-in **biometric** and **device-identifier** sections were already present on `origin/main`.

2. Description of the Data Processing System

Setnayan is a Philippines-first life-events platform (V1 surface: weddings, with additional event types — birthday, debut, christening, gender reveal, anniversary, reunion, corporate and others — progressively enabled). It provides three role-routed doorways:

- **Couples / customers** plan an event end-to-end (guest lists, vendors, budget, schedule, invitations, media galleries) and optionally record personalization and family-milestone details.
- **Vendors** run a business profile, submit verification documents, and receive inquiries.
- **Administrators** (the Setnayan team) run operations, payment reconciliation, and integrity / fraud review.

Personal data is processed to deliver the planning service, to enable couple↔vendor communication, to process in-app payments, to verify vendor legitimacy, and to protect the marketplace from fraud. Processing is web-based; data resides with the subprocessors in §7.

3. Records of Processing Activities (ROPA)

Personal-data categories, purposes, legal bases, and retention. Retention detail is maintained in the companion **Data Retention Schedule (2026-07-11)**; periods marked *(counsel)* await external ratification. **Build-state** column: *Active* = collected in production now; *Gated* = shipped behind a feature flag; *Dormant* = built but not yet collecting.

#	Data category	Data subjects	Purpose	Legal basis (RA 10173)	Retention	Build-state
1	**Account / profile** — email, hashed password, display name, optional phone, profile photo	Couples, vendors, admins	Account creation + authentication; deliver the service	§ 12(a) consent; § 12(b) contract	Life of account + 30-day soft-delete tail, then purge	Active
2	**Self-profile personalization — religion, civil status, gender/sex** *(sensitive PI)* + per-field consent timestamps (`religion_consent_at`, `civil_status_consent_at`, `sex_consent_at`)	Account holders (adults)	Optional personalization — faith-appropriate suggestions, event-type relevance, salutation. Reference-only; not required to use the service	§ 13(a) **explicit consent** (self-provided, timestamped; withdrawable)	Life of account; cleared on withdrawal or account deletion	**Active** (self opt-in; no feature flag)
3	**Event data** — guest lists, vendor records, budget items, schedule, mood-board palettes	Couples (and guests they enter)	Deliver event-planning features the user is paying for	§ 12(b) contract	5 years from event date *(counsel)*	Active

4	**Event honoree / specialty details** — e.g. christening **child name, birth date, gender** + rite; gender-reveal **parents' names + expected due-date**; birthday celebrant name + age; debut celebrant; wedding **ceremony rite** *(contains sensitive PI + minors' data — see §5)*	Couples; the named honoree (may be a minor or a non-account third party)	Configure the specific event the couple is planning	§ 12(b) contract; § 13(a) consent of the enrolling account holder / guardian for the honoree's sensitive attributes	With the event record, 5 years from event date *(counsel)*	**Active** (in `events.signature_detail` no feature flag, no separate consent timestamp — documented as-is; see §11)

5	**Family graph — dependents & godparents.** A dependent is a **person, a pet, or anything the user cares for** (`dependent_kind`). Only the **person** kind may carry name + **birth date, sex, religion** (+ guardian-consent timestamps) under the age fence; **pet / other carry only a name + optional birthday — no sensitive data.** Godparent: name, **email** (a third party), role, reminder preference	Account holder; their **person-dependents (which may be a minor or an elder)**; godparents (third parties)	Optional milestone tracking (upcoming faith rites, godchild-birthday reminders)	§ 12(b) contract; § 13(a) **guardian consent** (timestamped) for a person-dependent's sensitive attributes; § 12(f) legitimate interest for godparent reminders	Life of account; deleted on withdrawal / account deletion. A **person-child** shared record is readable by a spouse account under a household model and **retained after separation** for continued co-parenting access (owner-defined)	**Enabled in production** (owner/DPO flipped `NEXT_PUBLIC_DEPENDENT_PEOPL` 2026-07-16). **Ownership transfer at majority (2026-07-16/17):** a person-dependent's record can be CLAIMED by the data subject at 18 (RA 6809 age of majority — 18 for both sexes, distinct from the 18F/21M debut celebration ladder) via a single-use, 7-day, guardian-revocable link (bearer token; excluded from data exports; optionally emailed to a recipient address that is used once and stored nowhere). On claim, **ownership of the record moves to the data subject** — they gain full control including erasure; the former guardian retains read-only history; the record thereafter survives the guardian's account deletion and is deleted with the SUBJECT's account. Elders (already past majority) are claim-eligible from day one. Pet/other records never convert to an account; care can only be reassigned guardian→guardian. Godparent edges transfer with the claimed record.

6	**In-app messages** — couple↔vendor chat	Couples, vendors	Enable coordination between parties	§ 12(b) contract	5 years from event date *(counsel)*	Active
7	**Payment metadata** — order amounts, reference codes, channel, payment-proof screenshots	Paying users	Process + reconcile in-app payments; issue Official Receipts	§ 12(c) legal obligation (NIRC / BIR)	**10 years** — legal floor (BIR RR 17-2013)	Active
8	**E-gift receiving methods (Pabuya)** — the couple's own GCash / Maya / bank / PayPal handle, account name, and uploaded receiving-QR image	Couples	Display the couple's own gift-receiving details to their guests. **Setnayan never holds, routes, or records the movement of money** — the schema stores no amount, ledger, or settlement state	§ 12(b) contract (couple's own display data)	With the event record; deletable by the couple anytime	**Active** (public guest route reported enabled in production 2026-07-13)
9	**Contracts + e-signatures**	Couples, vendors	Vendor engagement records	§ 12(c) legal obligation; Civil Code Art. 1144	**10 years** — legal floor	Active
10	**Vendor-verification identity data** — government ID, business permits / registrations, and (where applicable) liveness selfie and sanctions / PEP screening result *(sensitive PI — see §5)*	Vendors (business owners)	Verify vendor legitimacy before a profile is trusted; marketplace safety	§ 12(b) contract; § 12(c)/(f) (fraud + AMLA-adjacent diligence)	Verification documents 90 days hot → cold retention to the statutory floor *(counsel)*	**Active** (documents collected; automated verification via Persona is staged — see §7)

11	**Biometric — facial-geometry vectors** *(sensitive PI)*	Guests/users who opt in (adults 18+)	Optional automatic photo-matching within a single event	§ 13(a) **explicit opt-in consent**, timestamped at enrolment	Per-event only; never reused across events; revocable on request. **Facial-geometry vector auto-expired (nulled) at ~5 years** by a scheduled per-event sweep (anchor = later of event date / enrolment); the underlying photo is retained. Selfie-asset purge-at-expiry is a DPO decision — §11	**Built; vector storage Dormant** (enrolment image-only until the matching model activates) — see §5
12	**Device identifier** — one-way hashed, first-party per-browser id	Signed-in users	**Fraud prevention** — detect fake / duplicate / sock-puppet accounts	§ 12(f) **legitimate interest** (fraud prevention + protecting vendors)	Life of account; rolling-prune device rows unused > 24 months *(counsel)*	**Dormant** — flag `NEXT_PUBLIC_DEVICE_FING` OFF in production; collects nothing pending DPO activation (§4)
13	**Guest RSVP details** — name, contact, **meal preference / dietary restrictions** *(health-adjacent)*, plus-one, photo/face-recognition preferences	Guests entered/invited by the couple	Deliver RSVP, seating, catering counts, and media-tagging preferences	§ 12(b) contract; § 13(a) consent for dietary/health-adjacent + face-recognition preferences	With the event record, ≤5 years *(counsel)*	Active
14	**Automatic technical data** — IP address (truncated to first 3 octets for QR-scan events), browser user-agent, timestamps	Site visitors	Security, abuse-prevention, service operation	§ 12(f) legitimate interest	Provider default / with related record	Active

15	~~**Product analytics**~~ — [X] **CORRECTED 2026-10-22: PostHog removed (PR #6774); no analytics service, no analytics cookie, no consent banner.** Replaced by first-party daily Visits aggregates with a daily-destroyed salted hash (ROPA DPS-21)	Site visitors	Site operation	§ 12(f) legitimate interest	Hashes 1 day; aggregates hold no personal data	Active (Visits)
16	**Error/diagnostic logs** — stack traces (Sentry; no message bodies, payment details, or guest data)	N/A (no PII by design)	Bug diagnosis + reliability	§ 12(f) legitimate interest; data-minimization	≤ 90 days	Active
17	**Marketing consent / communication preferences** (+ `marketing_consent_at`)	Couples, vendors	Proof of consent; honor preferences	§ 12(a) consent	Life of account + audit tail	Active
18	**Support tickets**	Users who contact support	Handle support requests	§ 12(b)/(f)	2 years	Active

19	**Samahan (group) memberships** — the group's **user-chosen name**, optional description, the member's role (organizer/member), join date, and a rotating invite token. **No classification/category field exists by design** (owner 2026-07-17): the platform never labels a group's nature or affiliation — the old `kind` taxonomy (which included `parish`, a religious-affiliation signal) was **removed at the schema level**, so no query, export, or breach can enumerate members by group type. A group's free-text name is the group's own speech, not a platform-assigned category	Account holders who create or join a samahan	User-initiated group formation (barkada/clan/org/etc. as THEY name it); rosters visible to fellow members only	§ 12(b) contract (user-initiated membership)	Membership row deleted on leaving the group or account deletion; included in the data export (`samahan_memberships`)	Active (live product); disclosed in the privacy notice "Samahan (groups)" section (2026-07-17)

~~20~~	(!) **WITHDRAWN 2026-07-20 — NEVER BUILT, PRODUCT CANCELLED. Do not lodge this row.** The flag named below (`NEXT_PUBLIC_PAPIC_LITE_ENABLED`) **does not exist in the codebase** — zero matches across `apps/web` + `supabase` @ `origin/main 5b72d625d` — and the product was cancelled 2026-07-20 before any processing occurred. Replacement note + rationale: [Papic_Compliance_Delta_2026-07-20.md] §3. (!) *"Papic Lite" also names a SHIPPED vendor on-the-day tier and a quality alias — see Delta §3.3 before deleting anything by name.* Original row text follows for lineage: **Papic Lite — open/crowd photo capture** (public-event QR; **photos only, no video, biometric-free — no facial-geometry vectors**). A shared photo pool for a large public event; captures **photographs that may include non-participant bystanders**; optional participant **join email** (magic-link claim) + consent timestamp + device/IP-hash (Sybil control)	Public-event attendees + bystanders; the hosting organizer (controller of the pool)	Let a host collect one shared photo pool for a public/large event (concert, tournament, corporate); each joiner keeps their own shots	§ 12(b) contract (host); § 12(a) join-consent (participants); bystander images on a public-space + posted-host-notice basis *(counsel)*	Full-res 6-month window then dropped; compressed gallery ≤5y. **Erasure = a public takedown/complaint form** (routes to host + admin) — the subject-access mechanism *because Lite has no face-search*	**Gated** — `NEXT_PUBLIC_PAPIC_LITE_` OFF in production; collects nothing until enabled, **blocked on DPO + external-counsel sign-off + a CSAM matcher** (see §11)

> (!) **ROPA GAP (2026-07-20) — a row is MISSING.** No row above covers the **photographs and ≤5-second clips Papic captures on guest and shooter phones** — row 3 ("Event data") does not name media, row 11 is the biometric *vector*, row 13 is an RSVP *preference*, and row 20 is withdrawn. This media is being collected on real events today. A drafted **row 21** (purpose, lawful basis, categories, subjects, retention, recipients, build-state) is at `Papic_Compliance_Delta_2026-07-20.md` §2.2, marked **`[PENDING DPO]`**.

> (!) **2026-07-30 — DO NOT FILE THE 2026-07-20 ROW-21 TEXT AS WRITTEN.** It says *"≤5-second video clips"*; the cap became **10 seconds** on 2026-07-22, so the old text would misstate a data category to the regulator. It also predates the two-type Pool/One model and guest-purchased shots. The corrected row 21, **plus two further missing rows** — **22** guest-authored public columns and **23** in-app voice/video calls (which owes a **Cloudflare TURN** subprocessor disclosure) — are drafted in `ROPA_Drafted_Rows_2026-07-30.md`, all **`[PENDING DPO]`**. That file also records that **two undeclared privacy-sensitive controls (`papic_pool_gallery`, `guest_columns`) went ACTIVE in prod on 2026-07-27** — live processing with no filing row, which is the sharpest form of this gap.

Right-to-erasure interaction: an account-deletion request deletes the subject's personal data **except** records under a legal-hold floor (rows 7 & 9 — payments and contracts), which are retained under the legal-obligation basis for the statutory period and then disposed of. This carve-out is disclosed in the privacy notice. *(Known remediation: account hard-delete does not yet purge chat-message PII — tracked in §11 and the Data Retention Schedule §4.)*

---

4. Privacy Impact Assessment — Device-Fingerprint Capture (fraud prevention)

A PIA of the **newest and most scrutiny-worthy** processing activity (ROPA row 12). **LIVE — collecting in production since 2026-07-12.** (!) CORRECTED 2026-08-17: this was described as built-but-switched-off. Measured in production on 2026-08-17: 9 device rows across 4 accounts, first written 2026-07-12, most recent the same day as this correction. The 2026-07-23 instruction to hold it off was SUPERSEDED on 2026-07-24 by the owner-locked Interim Payments & Privacy Deferral Policy, which deliberately activated it; the live public /privacy notice discloses device-fingerprint processing accordingly. Basis relied on: RA 10173 §12(f) legitimate interest (fraud prevention). STILL OWED: the documented legitimate-interest assessment (NPC task t2-10). Collection is coarse and first-party — a random id in localStorage, hashed server-side, raw never stored; no canvas/behavioural fingerprint and no external SDK; secured accounts only. *(As of 2026-07-13 the flag `NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED` is confirmed OFF in production. A separate draft Anti-Fraud Policy amendment references this processing as active from 2026-07-07; that statement is ahead of the actual flag state and is being corrected — see §11.)*

4.1 What is processed and why

To protect couples and vendors from coordinated fraud (a single bad actor — often a competing vendor — spinning up many fake couple accounts to spam a vendor's inbox or drain the token a vendor spends to answer an inquiry), Setnayan must recognize when several "different" accounts are in fact the **same device**. On a signed-in session, the browser generates a **random identifier** stored in local storage; it is transmitted to Setnayan's server and **one-way hashed (SHA-256 with a server-side salt)**. Only the hash is stored, against the account. Two accounts sharing a device produce the same hash, which lets the existing fraud-clustering logic **flag them for human review** — it never auto-bans anyone.

4.2 Necessity and proportionality

- **Necessary:** vendors are charged per inquiry; fake inquiries are a direct, quantifiable financial harm, and account-level signals alone cannot detect one actor behind many accounts.
- **Proportionate / least-intrusive:** the signal is a **random id**, deliberately **not** a behavioral or biometric fingerprint (no canvas/font/WebGL probing) and uses **no third-party tracking SDK**. It identifies a *browser*, not a person's activity, and is never used for advertising, personalization, or cross-site tracking.

4.3 Legal basis

Legitimate interest under § 12(f): preventing fraud and protecting the marketplace and its vendors. Balancing test — the intrusion is minimal (a fraud-only pseudonymous hash), the interest is substantial, and the practice is disclosed. The data is **not** sensitive personal information.

4.4 Risks and mitigations

Risk	Mitigation
Re-identification of an individual	Value is a **one-way hash of a random id** (raw value never stored); pseudonymous; no linkage to browsing behavior
Function creep (used beyond fraud)	**Purpose limitation** enforced in code + policy; used only for identity-cluster fraud review; never sold or shared
Over-collection	**Signed-in accounts only**; one hash per (account, device) + a last-seen timestamp; **no IP stored** for this signal
Data-subject unawareness	**Already disclosed** in the public privacy notice (the "Device identifier (fraud prevention)" section), ahead of activation
Unlawful retention	Retention clock (life of account; rolling-prune > 24 months); included in data export; deleted on account deletion
Activation without oversight	**Flag-gated OFF**; activation requires DPO sign-off; fully reversible from a single toggle

4.5 Residual assessment

With the above controls, residual privacy risk is **LOW**. The privacy-notice disclosure is already published; the remaining gate is the DPO's activation decision.

---

5. Sensitive Personal Information (RA 10173 § 13)

RA 10173 § 3(l) / § 13 treats as **sensitive** an individual's race/ethnic origin, marital status, age, religious/philosophical/political affiliations, health, education, genetic or sexual life, and government-issued identifiers, and gives biometric data special status. Setnayan processes the following sensitive categories, each on the noted basis:

Sensitive category	Where it appears	Basis	Safeguards
Religion / faith	Self-profile `religion` (ROPA 2); wedding **ceremony rite** and Islamic-rite fields (mahr, seating posture, wali/witness/imam roles) and Chinese/Tsinoy rite (ROPA 4); dependent's religion (ROPA 5)	§ 13(a) explicit consent (self / guardian), timestamped where captured at profile level	Optional; withdrawable; never sold or used for advertising; faith surfaced only to the couple's own event workspace
Marital / civil status	Self-profile `civil_status` (ROPA 2)	§ 13(a) explicit consent, timestamped	Optional, reference-only

Age / minors' data	A **person**-dependent's **birth date** — only `kind=person`, and only a child (<18) or elder (>50); pets/other excluded (ROPA 5); christening **child birth date + gender**; birthday **celebrant age** (ROPA 4)	§ 13(a) guardian consent; § 12(b) contract	Minors' data arises only where the responsible adult enters a child — it is **not the defining purpose** of the dependents table; heightened-care handling
Health-adjacent	Guest **dietary restrictions / meal preference** (ROPA 13); gender-reveal **expected due-date** (ROPA 4)	§ 13(a) consent	Collected only where the event requires it; not used beyond the event
Gender / sex	Self-profile `sex` (ROPA 2); dependent / honoree sex (ROPA 4-5)	§ 13(a) consent, timestamped at profile level	Optional; reference-only
Biometric — facial geometry	Optional per-event photo-matching (ROPA 11)	§ 13(a) explicit opt-in consent, timestamped	Adults 18+; **scoped to a single event, never reused across events**; consent withdrawal permanently deletes the vector + selfie; **vector storage currently dormant** (enrolment image-only until the model activates)
Government ID + sanctions/PEP screening	Vendor verification (ROPA 10)	§ 12(b)/(c)/(f)	Vendor business owners only; restricted-access; retained to the statutory floor then disposed

Users who provide none of the optional categories (religion, civil status, gender, biometric enrolment, dependents) supply no sensitive personal information beyond what a given event type strictly requires. The presence of these sensitive categories is a basis for **NPC registration** (§ 5 IRR registration triggers).

> **Note (2026-07-13):** the public notice **already** carries an accurate opt-in **Biometric data (facial recognition)** section (explicit consent, adults 18+, per-event scope, withdrawal → permanent deletion) and a **Device identifier (fraud prevention)** section — the earlier "notice denies biometrics / omits the device identifier" concern came from a **stale local checkout**, not the deployed `origin/main`. Face-vector storage is currently **dormant** (enrolment image-only until the matching model activates), which the section's opt-in framing already accommodates.

---

6. Data Subject Rights (RA 10173 § 16)

Setnayan honors the rights to be **informed, access, object, rectify/correct, erase or block, data portability, and to lodge a complaint / claim damages**. Operationally:

- **Access + portability:** a self-service "download my data" export (iteration 0025) that includes the sensitive-personalization and family-graph fields.
- **Erasure/blocking:** soft-delete → hard-delete of account data, subject only to the legal-hold carve-out (§ 3). Withdrawing religion / civil status / gender / biometric / dependent consent deletes the corresponding data.
- **Objection/withdrawal:** (analytics opt-out retired 2026-10-22 — there is no analytics to opt out of); face-recognition consent revocation (deletes the vector); marketing-preference controls.

- **Correction:** profile/settings self-edit.
- **Complaints:** routed to the DPO at dpo@setnayan.com; **15-business-day** response SLA; the data subject retains the right to complain to the NPC.

---

7. Subprocessors and Cross-Border Transfers (§ 21)

Setnayan uses the following subprocessors. Cross-border transfers rely on § 21 and each provider's adequacy/contractual commitments.

Subprocessor	Function	Location	Notes
Supabase	Database + authentication	Singapore	Primary data store; RLS enforced
Vercel	Web application hosting	US company; functions in Singapore (`sin1`)	Updated 2026-10-22
Cloudflare	R2 object storage (media) · TURN live-video relay · Turnstile bot check · STUN	Asia-Pacific (APAC) buckets; global network	Relay and bot check only when their keys are set (updated 2026-10-22)
Resend	Transactional email	United States	
Sentry	Error monitoring — server and browser; masked replay on a browser error (all text masked, media blocked); e-mail / phone / face-vector scrubbing	United States	Updated 2026-10-22 (was "server-side, stack traces only")

~~PostHog Cloud~~	~~Product analytics~~	—	[X] **REMOVED 2026-10-22 (PR #6774)** — essential cookies only, no banner, no analytics SDK
Anthropic	Payment-receipt reading · supplier Deep Search · supplier gallery screening · theme sentence	United States	No training on user data; never decides a payment (updated 2026-10-22)
OpenAI	Moderation of published couple / guest text	United States	Added 2026-10-22
LanguageTool	Grammar check (free public API)	Germany (EU)	Added 2026-10-22 — no DPA possible on the free endpoint
Apple	Sign in with Apple; App Store in-app purchase (built, switched off); iTunes song search	United States	Added 2026-10-22
Meta · OpenStreetMap · Vimeo · browser push services	Social posting / Instagram sync · maps · poster image · web push	US / UK / various	Added 2026-10-22

~~Persona~~	~~Vendor identity verification~~	—	[X] **RETIRED 2026-07-03, struck 2026-10-22** — never engaged, no data ever sent
Google LLC	Sign-in (behind a switch); Google Drive / YouTube (only when the user connects); Gemini image model for paid mood-board renders; STUN	United States	OAuth, opt-in; Google **Limited Use** commitment (no AI/ML training). Updated 2026-10-22
TikTok	Patiktok video publish (only when the user connects the optional integration)	United States / Singapore	OAuth, opt-in; scopes limited to profile + video upload/publish
Suno	AI music, used by hand by the team	—	**Not called by the code**; no personal data — not a processor (updated 2026-10-22)

Backblaze B2	Cold object storage — Papic compressed-gallery cold tier at scale	United States	**Not yet active** — flag-gated; engaged only once the aggregate cold pile reaches ~tens of TB
CSAM hash-matching provider (e.g. PhotoDNA / NCMEC)	Known-illegal-image hash matching for **any open-crowd capture (corporate / tournament)** — *restated 2026-07-20: the cancelled "Papic Lite" product is no longer the trigger; the duty travels with open-crowd ingest (`Papic_Compliance_Delta_2026-07-20.md` §3.2)*	United States	**Not yet engaged** — and **no open-crowd capture is offered in V1**; mandatory-repo duty to be reviewed by counsel before any such capture ships

Cross-border destinations disclosed (updated 2026-10-22): Singapore (Supabase; Vercel functions), United States (Vercel company, Cloudflare account plane, Resend, Sentry, Anthropic, OpenAI, Google, Apple, Meta, Vimeo), Germany (LanguageTool), United States/Singapore (TikTok). PostHog removed; Persona retired; Suno not called. Media objects reside in Cloudflare R2 buckets in the Asia-Pacific (APAC) region (there is no Philippines region in R2).

---

8. Organizational, Physical, and Technical Security Measures

- **Access control:** database Row-Level Security (RLS) on all tables (enabled at table creation); role-scoped access; two-admin approval gates for major administrative decisions.
- **Cryptographic controls:** passwords hashed; the device identifier is a **one-way salted hash** (raw value never stored); OAuth grants encrypted at rest; transport over TLS.

- **Data minimization:** analytics carry no personal identifiers; error logs exclude message bodies, payment details, and guest data; IP truncated to 3 octets for QR-scan events. *(Minimization item: some aggregate dashboard views load fuller records than they display — a tightening pass is tracked in §11.)*
- **Content safety:** an NSFW filter is on by default and cannot be disabled.
- **Confidentiality by design:** vendor identity masking (a vendor sees only the couple's event display name + date, never their email or personal name unless shared).
- **Residency:** database in Singapore; media in Cloudflare R2 **Asia-Pacific (APAC)**. (!) **CORRECTED — there is no PH region in R2**, and the old wording implied a Philippine residency we do not have.
- **Breach response:** the DPO coordinates assessment and any NPC + data-subject notification within the periods required by the NPC's breach rules.

8a. Retention governance

Retention is bounded on both ends: **RA 10173 storage-limitation** as the maximum, and **statutory floors** as the minimum for financial and contractual records (BIR RR 17-2013 = 10 years for payments/Official Receipts; Civil Code Art. 1144 for contracts). Per-class periods are maintained in the **Data Retention Schedule (2026-07-11)**; periods marked *(counsel)* await external ratification.

> [OK] **RESOLVED 2026-08-07 — and read this before "fixing" the paragraph below.** The superseded note here told the reader that the paragraph beneath it — *"a compressed web copy is retained indefinitely"* — had to be reconciled DOWN to a 5-year purge, and declared itself blocking on "all retention marketing copy". **That is exactly backwards, and it is the single most likely cause of this error recurring a fourth time.**

> **What is true:** *"indefinitely"* for the compressed copy is **correct and stays**. It is the owner's lock ("free forever, never deleted"), it is what the code does, and the 5-year media period it was measured against has itself been retracted in `Data_Retention_Schedule_2026-07-11.md` row 2. Only the day numbers moved: the full-resolution window is **6 months from the event's first capture, floored at 3 months after the event date** (`DEFAULT_FULL_RES_RETENTION_DAYS = 183`, `FULL_RES_POST_EVENT_GRACE_DAYS = 92`), not the 90 days this note cited.

> **AND NOTHING IS DELETED.** The full-resolution original is **replaced by** the compressed copy, which the gallery keeps for good; `isEligibleForDrop` refuses to act at all when that copy is missing. Owner, twice: *"again. not delete. just compress."* **Do not re-introduce a 5-year media purge into any copy, filing or marketing sentence.**

> **What genuinely remains open** is narrower: the lawful **BASIS** for indefinite retention of photographs of identifiable people (including guests who are not our customers), not the period. That reasoning must be written down and reviewed by counsel before lodging — "the owner decided" is not a lawful basis.

Papic media lifecycle (2026-07-17). Captured photos and 5-second clips are kept at full resolution for **6 months** (for the couple to download or sync to their own Google Drive). After the window the full-res original is **replaced by the compressed web copy** in Setnayan storage (the photo itself remains in the gallery), unless the couple has synced the original to their Drive; a **compressed web copy** (photos + compressed clip copies) is retained on the couple's gallery **free, for life** as the serving copy (owner 2026-08-18, *"we keep it for life"*, superseding the 2026-08-07 five-year window and its never-built paid option; nothing was ever deleted under either) — so no media type carries an unbounded FULL-RESOLUTION tail. Optional facial-geometry vectors (ROPA 11) auto-expire per event at ~5 years; the account-level face profile is governed by account deletion, not this per-event clock. Papic Lite (ROPA 20) is photos-only and biometric-free.

9. Compliance Statement

Setnayan processes personal data under RA 10173 on the bases recorded in § 3, with retention bounded on both ends (RA 10173 storage-limitation as the maximum; BIR/Civil Code statutory floors as the minimum for financial and contractual records). Data subject rights are implemented and honored; sensitive personal information (religion, civil status, gender, minors' data, health-adjacent data, biometric, and vendor government-ID) is processed only on the bases in § 5; the fraud-prevention device identifier is minimized, pseudonymized, and DPO-gated (currently dormant). The DPO is the proprietor and is the point of contact for the NPC and for data subjects.

Prepared by (DPO): ___ (Indalecio S. Casasola II) — dpo@setnayan.com

Date: 2026-07-13

10. Appendix — companion documents

- `Privacy_Reconciliation_Home_and_Data_Flows_2026-07-13.md` — the reconciliation that drove the v2.0 expansion.
- `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12.md` — DPO one-pager for the device-fingerprint processing.
- `Data_Retention_Schedule_2026-07-11.md` — full per-class retention schedule + `[PENDING COUNSEL]` items.
- **`Papic_Compliance_Delta_2026-07-20.md` — (!) the three open defects in THIS draft (retention 90 d vs 6 mo · missing media ROPA row · the false "Papic Lite is built" claim) plus the RSVP-consent question for DPO ruling. Read before lodging.**
- `NPC_Compliance/` pack — the deeper filing set (Privacy Manual, full RoPA, DPO Designation + NPCRS data sheet, Breach Policy, DPIA register, Face-Vector DPIA, Anti-Fraud DPIA). This dossier is the executive summary over that pack; the two must be kept consistent.
- `01_Contracts/Setnayan_Privacy_and_Security_Policy.md` — the binding public policy (to be reconciled per §11).
- Public privacy notice — `setnayan.com/privacy`.
- `[[dpo-designation-owner]]` — DPO designation record.

11. Open items before filing (owner / DPO / external counsel)

Blocking on external counsel (this dossier is not legal advice):
1. External counsel review of this dossier + the retention periods marked *(counsel)*, with specific attention to the **§ 3(l) / minors' data** cluster (dependents, christening child data, godparent third-party notification) and the vendor **AMLC/PEP + government-ID** screening basis.
2. Confirmation of the **NPC registration threshold** applicable to the business.

Owner / DPO actions (documentation + product):
3. **Public privacy notice — DONE (app PR #3215, 2026-07-13):** added the **faith / family / honoree / e-gift** disclosures + Anthropic/Suno subprocessors; the opt-in **biometric** and **device-identifier** sections were already present. Remaining notice work is wording refinement by counsel, not a coverage gap.
4. **Reconcile the older corpus documents** to the values in §1: standardize the DPO contact to `dpo@setnayan.com` (owner-locked 2026-07-24; the `dpo@setnayan.com` variant is retired) and the 7-business-day SLA → 15 in the binding Privacy & Security Policy; add the **10-year floor** and the **vendor-verification retention class** to that policy's §4 retention table; add **Persona, TikTok, Suno** to its §10 subprocessor table.
5. **Device-fingerprint status:** correct the draft Anti-Fraud Policy amendment's "active since 2026-07-07" language to

match the confirmed **flag-OFF** state, and gate the notice disclosure to activation.
6. **Known product remediation** (tracked, not blocking this draft): account hard-delete does not yet purge chat-message PII (Retention Schedule §4); the `events.signature_details` honoree fields (christening child data, gender-reveal due-date) collect sensitive data without a per-field consent timestamp — **documented as-is per owner direction**, flagged here for a future consent-instrumentation pass; and the dashboard data-minimization tightening in §8.

Papic v3 (added 2026-07-17):
7. (!) **WITHDRAWN 2026-07-20 — this item states a falsehood about our own system.** The pool described below was **never implemented** (no flag, table, route or migration; zero code matches) and the product was **cancelled 2026-07-20** before any processing occurred. Replacement wording is drafted at `Papic_Compliance_Delta_2026-07-20.md` §3.2; the bystander / minors-in-crowd / CSAM questions are **deferred, not closed** — they attach to any future open-crowd event type. Original text for lineage: *Papic Lite public-launch gate (counsel + DPO) — blocking Lite only.* The open, public-QR photo pool (ROPA 20) is built but flag-OFF. Enabling it requires sign-off on: bystander/subject consent at QR-join; the **public takedown/complaint mechanism** that serves the erasure right absent face-search (Lite is biometric-free); a minors-in-crowd notice (concerts/reunions/tournaments); and a **CSAM known-hash matcher + mandatory-reporting** review before an anonymous public upload endpoint goes live. Wedding Papic is unaffected.
8. **Face-vector 5-year expiry (DPO).** Confirm the expiry anchor (event date vs enrolment) and whether the enrolment **selfie** biometric asset is purged at expiry or retained (default proposed: null the vector, retain the photo). Add the sweep to the Data Retention Schedule + Face-Vector DPIA.
9. **(!) Security-statement reconciliation (before filing).** §8 states "OAuth grants encrypted at rest," but the Papic build review found the Google-Drive `oauth_grants.refresh_token` / `access_token` stored **in plaintext** today. Either implement application-layer encryption to make the statement true, or correct §8 — a submission must not overstate a technical control.

> **Filing note.** This is a complete, DPO-prepared submission draft: the ROPA, PIA, sensitive-PI declaration, subprocessor list, security measures, and data-subject-rights implementation are all present and reconciled to the as-built platform as of 2026-07-13. It is **ready for external counsel review**, which — together with items 1-2 above — is the final gate before lodging with the NPC.